HKCT Higher Diploma in Cybersecurity (Testing and Compliance)

03CIT4067 Cybersecurity Project Bi-weekly Meeting

Minutes of the 1st Bi-weekly Meeting

Date: 2023-10-06 (Friday)
Venue: MUC 507 (face-to-face)
Participants:

Students:
Hui Ka Tung. Troy
Huang Kin Ming, William
Shi Hau Yan, Jessie

Lecturer : Liam Xu

Apologies:

Item	Description	Lecturer Feedback	Action by
Agenda #1	Topics Introduction	Approved	
Agenda #2	Latest Phishing Email Techniques	Combine issues and case examples into 1 part	Wait for the testing result on #3
2.1	How the malicious actor acts		
2.2	How the victims are tricked		
2.3	What techniques are used		
Agenda #3	Exiting tools from Github	Test these three tools on 1 scenarios that all tools can solve	Troy : PhishGuard AI

3.1	How does the tool perform		Jessie : PhishGuard William : NLP
3.2	What are their functions		
3.3	What we could take reference on		
3.4	What unique features we could add on our project	combine the three tools result and generate a more comprehensive graphic and score criteria	
Agenda #4	Date of next meeing	20/10/2026	

Reference:

1. Salloum, S., Gaber, T., Vadera, S., & Shaalan, K. (2022). A systematic literature review on phishing email detection using natural language processing techniques. *Ieee Access*, *10*, 65703-65727.
2. Thakur, K., Ali, M. L., Obaidat, M. A., & Kamruzzaman, A. (2023). A systematic review on deep-learning-based phishing email detection. *Electronics*, *12*(21), 4545.

2.1 How the malicious actor acts (behaviors + cases, what is phishing)

- **social engineering**
- **AI**

1. 濫用可信電郵基礎設施（Trusted Email Infrastructure）

攻擊者透過Amazon SES、Google服務或其他合法雲端郵件服務發送郵件，令郵件通過身份驗證檢查。寄件域名與DKIM簽名對齊，看起來像正常商業郵件。內容通常沒有附件，只有連結。

- Identified issues examples

2. 多階段URL隱藏與偽裝（URL Cloaking / Redirect Laundering）

郵件中的連結先導向合法服務（如Google Meet、Search、DoubleClick、Microsoft SafeLinks、Cisco Secure Web等），經過多層跳轉、瀏覽器指紋偵測與反機器人檢查後，才顯示真正的釣魚頁面。部分使用IPv6映射地址或Blob URL（在受害者瀏覽器記憶體中動態生成頁面），令傳統掃描器難以事先偵測。

- Identified issues examples

3. AI生成內容與高度個人化

使用生成式AI撰寫語氣自然、語法完美的郵件，模仿企業內部溝通或官方通知風格，並加入受害者相關的背景資訊（如近期訂單、會議或公開資料）。常見主題包括發票、退款、帳戶安全、文件共享、Code of Conduct確認等。水印?

4. 隱形Unicode字符（ASCII Smuggling變體）

在關鍵字（如「funding」）中插入隱形Unicode標籤字符，令收件人看到正常文字，但郵件過濾器的關鍵字規則或部分機器學習模型被干擾，難以準確匹配。

5. 日曆邀請（Calendar Invite）與假附件預覽

附加.ics日曆檔案或在郵件正文中模擬Gmail附件預覽卡片，增加「正常商務郵件」的感覺。點擊後導向假登入或裝置代碼授權頁面。

6. 內部轉發式攻擊（CalPhishing）

攻擊者先以潛在客戶身份聯絡非銷售部門員工，請求轉介；再提供「預約會議連結」要求轉發給真正目標。轉發郵件因此帶有同事的可信度，大幅降低懷疑。

7. 其他常見變體

假冒Zoom、DocuSign、Microsoft 365、銀行、水務署、航空公司退款等。
結合AiTM反向代理，竊取會話權杖而非單純密碼。
使用被入侵的真實帳戶發送郵件，進一步提高可信度。
部分郵件引導受害者接聽「客服」電話（callback phishing），轉為語音釣魚。

2.2 How the victims are tricked (combined 2.1 as results, damage of phishing)

- 製造「正常」與緊急感：郵件看起來完全合法（通過驗證、無明顯惡意附件），內容緊扣日常工作（發票、共享文件、安全更新、退款），要求「立即處理」或「確認身份」。

- 利用信任鏈：透過合法服務跳轉、同事轉發或真實寄件帳戶，令受害者放鬆警惕。

點擊後才暴露：郵件本身乾淨，惡意頁面只在真實用戶點擊後（並通過指紋檢查）才出現，掃描器常誤判為安全。

- AI個人化降低懷疑：內容高度貼合受害者情境，幾乎沒有傳統「文法錯誤」等破綻。

多渠道後續：電郵成功後，可能接續語音電話或Teams訊息，引導完成授權或輸入OTP。

香港相關觀察：本地案例常仿冒航空公司退款、政府部門帳單、銀行通知或物流服務，結合短訊與電郵雙管齊下，誘騙輸入信用卡或網銀資料。

2.3 Techniques Used

- Amazon SES、Google服務或其他合法雲端郵件服務
- AI Content
- ASCII Smuggling變體
- .ics日曆檔案/ Zoom Invitation Links
- CalPhishing

3abc. Exiting tools from Github

1. **iampopg**

簡介：開源、自託管、離線優先的郵件釣魚偵測引擎。支援上傳 .eml、原始文字、URL 或即時 IMAP 信箱掃描。有 9 個透明分析器（Header Auth、Domain Reputation、URL、Content、Attachment、Behavioral、Org Context、Sandbox 等），加權評分（0–100），可輸出完整解釋報告。提供 CLI + Next.js Web Dashboard，支援 Docker。
Demo 影片：目前未發現公開正式 demo 影片。README 有功能截圖與架構圖，專案仍處於 beta 階段。
是否涵蓋最新手法：

Email Infrastructure（較佳）：明確檢查 SPF / DKIM / DMARC 驗證與對齊，可偵測寄件人身份異常。對「通過驗證但仍可疑」的郵件有一定防禦。

ASCII Smuggling：文件中未提及專門偵測隱形 Unicode 標籤字符的功能。傳統內容分析可能無法有效抓出此手法。

整體：對傳統與部分進階郵件釣魚有不錯覆蓋（含 BEC 行為分析），但對 2026 年多階段 URL 隱藏、Bl

2. fitsblb

簡介：現代化、可解釋的釣魚 **URL** 偵測工具。使用 FastAPI、政策分級（policy bands）、LLM 輔助審核。強調本地或 Docker 快速部署，有 Jupyter Notebook。
Demo 影片：未發現專屬此 repo 的正式 demo 影片。相關名稱「PhishGuard AI」的其他專案有 YouTube 示範（多為 hackathon 或類似工具），但非此專案本身。
是否涵蓋最新手法：

- **Email Infrastructure**：幾乎不涵蓋（主要針對 URL，而非完整郵件 headers／認證）。
- **ASCII Smuggling**：未提及相關偵測。
- 整體：適合 URL 層級快速掃描與解釋，對完整郵件攻擊鏈（尤其是通過合法基礎設施的郵件）覆蓋不足。

3. NLP

ScamShield-nlp（yash9769 等）
多個 PhishGuard AI 變體（使用 TF-IDF、SVM、BiLSTM、DistilBERT、BERT 等）
其他以內容分類為主的工具
簡介：以自然語言處理（NLP）與機器學習為主，分析郵件／簡訊內文的語意、緊急用語、社交工程特徵。部分提供即時 Dashboard、可解釋 AI（XAI）、FastAPI 後端。
Demo 影片：部分專案有 live demo 或 YouTube 示範（例如貼上郵件內容後即時分類、顯示信心分數與關鍵字解釋）。多數可自行部署後體驗。
是否涵蓋最新手法：

- **Email Infrastructure**：通常較弱（較少完整檢查 SPF/DKIM/DMARC 或基礎設施來源）。
- **ASCII Smuggling**：除非特別加入 Unicode 分析特徵，否則幾乎無法偵測隱形字符（因為內容看起來正常）。

- 整體:對 AI 生成內容、緊急話術、語意異常有較好效果, 但對「通過驗證 + 隱形字符 + 多層跳轉」的 2026 年進階手法覆蓋有限

3d. What unique features we could add on our project

- Google Extensions

4. Tutor Feedback

- Analyze the scarenios
- Actual Cases
- Tools Performance
- Combine Performance result of each tools



- Revise the graphs
- Decide KPI and calculation
- Jira work graph

Data set → tools (.json files {graphics} → mark down report {download}) → Combination → equation → result

3 tools → success scenarios → Part I

education purpose → social engineering

Confirmed and signed by

2026-10-06